Projet personnel de cybersécurité

Audit de configuration de sécurité et durcissement des actifs SI dans une démarche de conformité CIS

Windows 11 · FortiGate · CIS Benchmarks

Réalisé par

Salma Bender

2026

Table des matières

Liste des figures iii

Liste des tableaux iv

Liste des abréviations v

1 Contexte et problématique 1

1.1 Contexte . . . 1

1.2 Les différents types d'audit de sécurité . . . 1

1.3 Audit de configuration et audit de conformité . . . 2

1.4 Problématique . . . 2

1.5 Objectifs . . . 3

1.6 Organisation du document . . . 3

2 Élaboration des guides et des checklists d'audit des actifs de sécurité 4

2.1 Introduction . . . 4

2.2 Présentation des actifs étudiés . . . 4

2.2.1 Windows 11 . . . 4

2.2.2 Pare-feu FortiGate . . . 5

2.3 Présentation des référentiels de sécurité . . . 7

2.3.1 Loi n°05-20 . . . 7

2.3.2 Direction Générale de la Sécurité des Systèmes d'Information (DGSSI) . . . 7

2.3.3 Directive Nationale de la Sécurité des Systèmes d'Information (DNSSI) . . . 7

2.3.4 CIS Benchmarks . . . 7

2.4 Méthodologie d'élaboration des guides . . . 8

2.5 Guide d'audit Windows 11 . . . 8

2.5.1 Objectif du guide . . . 8

2.5.2 Structure du guide . . . 8

2.6 Guide d'audit FortiGate . . . 9

2.6.1 Objectif du guide . . . 9

2.6.2 Structure du guide . . . 9

2.7 Élaboration des checklists d'audit 10
2.7.1 Objectif des checklists 10
2.7.2 Structure des checklists 10
2.7.3 Utilisation des checklists 11
2.7.4 Checklist Windows 11 11
2.7.5 Checklist du pare-feu FortiGate 12
2.8 Conclusion 12

3 Mise en œuvre du durcissement et validation des résultats 13
3.1 Introduction 13
3.2 Présentation de l'environnement de test 13
3.3 Durcissement du poste Windows 11 14
3.3.1 Audit initial 14
3.3.2 Simulation d'une attaque par force brute sur RDP 16
3.3.3 Mise en œuvre du durcissement 17
3.3.4 Résultats après durcissement 18
3.3.5 Nouvelle simulation d'attaque après durcissement 21
3.3.6 Comparaison avant et après durcissement 22
3.4 Durcissement du pare-feu FortiGate 23
3.4.1 Environnement du FortiGate 23
3.4.2 Audit initial 23
3.4.3 Analyse de l'exposition réseau avant durcissement 24
3.4.4 Mise en œuvre du durcissement du FortiGate 25
3.4.5 Audit après durcissement du FortiGate 27
3.4.6 Justification des contrôles non conformes 27
3.4.7 Comparaison avant et après durcissement 28
3.5 Conclusion 29

Conclusion générale 30

Bibliographie 31

Liste des figures

2.1 Architecture générale d'un pare-feu FortiGate 6
2.2 Extrait du guide d'audit de Windows 11 9
2.3 Extrait du guide d'audit du pare-feu FortiGate 10
2.4 Extrait de la checklist d'audit Windows 11 11
2.5 Extrait de la checklist d'audit FortiGate 12

3.1 Tableau de bord du rapport d'audit avant le durcissement du poste Windows 11 14
3.2 Résultats détaillés de l'audit CIS du poste de travail Windows 11 avant durcissement 15
3.3 Lancement de la simulation de force brute RDP depuis Kali Linux 16
3.4 Résultat de la simulation d'attaque RDP avec Hydra 16
3.5 Exécution du script de durcissement du poste Windows 11 18
3.6 Rapport d'état de sécurité après durcissement de Windows 11 19
3.7 Détail des contrôles de sécurité après durcissement 20
3.8 Simulation de force brute RDP après durcissement 22
3.9 Rapport d'audit initial du FortiGate 23
3.10 Identification du service HTTPS du FortiGate avant durcissement 24
3.11 Reconnaissance des services du FortiGate avant durcissement 25
3.12 Rapport d'audit de conformité du FortiGate après durcissement 28

Liste des tableaux

1.1 Niveaux de maturité de la mise en œuvre des contrôles de sécurité 2

3.1 Environnement de test 13
3.2 Synthèse des principales mesures de durcissement 19
3.3 Analyse des principales non-conformités restantes 21
3.4 Évolution du niveau de conformité de Windows 11 après durcissement 22
3.5 Synthèse de l'audit initial du FortiGate 24
3.6 Justification des contrôles non conformes 28
3.7 Évolution du niveau de conformité du FortiGate avant et après durcissement . . 28

Liste des abréviations

CIS	Center for Internet Security
DGSSI	Direction Générale de la Sécurité des Systèmes d'Information
DNSSI	Directive Nationale de Sécurité des Systèmes d'Information
HA	High Availability
HTML	HyperText Markup Language
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
HVCI	Hypervisor-Protected Code Integrity
IAM	Identity and Access Management
IPS	Intrusion Prevention System
LAN	Local Area Network
MDM	Mobile Device Management
NGFW	Next Generation Firewall
NSE	Nmap Scripting Engine
NTP	Network Time Protocol
PKI	Public Key Infrastructure
RDP	Remote Desktop Protocol
SMB	Server Message Block
SSH	Secure Shell
SSL	Secure Sockets Layer
TCP	Transmission Control Protocol
TLS	Transport Layer Security
TPM	Trusted Platform Module
VBS	Virtualization-Based Security
VM	Virtual Machine
VPN	Virtual Private Network
WAN	Wide Area Network

Chapitre 1

Contexte et problématique

1.1 Contexte

Face à l'évolution constante des cybermenaces, les établissements bancaires sont confrontés à des défis majeurs en matière de protection de leurs systèmes d'information. Les actifs du système d'information d'un établissement bancaire constituent des éléments critiques qui doivent être configurés conformément aux bonnes pratiques de sécurité afin de limiter les risques d'exploitation des vulnérabilités.

1.2 Les différents types d'audit de sécurité

L'audit de sécurité des systèmes d'information est une démarche méthodique visant à évaluer le niveau de protection des actifs informatiques d'une organisation. Il permet d'identifier les risques, de détecter les vulnérabilités de sécurité et de vérifier l'efficacité des mesures de protection mises en œuvre. Selon les objectifs recherchés, plusieurs types d'audits peuvent être distingués :

- **Audit organisationnel** : il porte sur la gouvernance de la sécurité, les politiques, les procédures et les responsabilités afin d'évaluer l'organisation de la sécurité des systèmes d'information ;
- **Audit technique** : il consiste à examiner les configurations des systèmes d'exploitation, des équipements réseau, des applications et des dispositifs de sécurité afin d'identifier les faiblesses techniques ;
- **Audit de vulnérabilités** : il utilise des outils spécialisés pour détecter automatiquement les vulnérabilités connues susceptibles d'affecter les actifs du système d'information ;
- **Test d'intrusion (pentest)** : il simule des scénarios d'attaque réels afin d'évaluer la capacité des systèmes à résister à une tentative d'exploitation ;
- **Audit de configuration** : il vérifie que les paramètres de configuration des systèmes et des équipements sont conformes aux bonnes pratiques de sécurité et aux recommandations des référentiels applicables ;
- **Audit de conformité** : il consiste à évaluer le respect des exigences définies par les lois, réglementations, normes et référentiels de sécurité adoptés par l'organisation.

Ces différentes formes d'audit sont complémentaires et permettent d'obtenir une vision globale du niveau de sécurité du système d'information.

1.3 Audit de configuration et audit de conformité

Le présent projet s'inscrit dans une démarche d'audit de configuration et d'audit de conformité.

L'audit de configuration consiste à analyser les paramètres de sécurité des actifs afin de vérifier qu'ils sont configurés conformément aux recommandations des référentiels de sécurité. Il permet d'identifier les erreurs de configuration susceptibles d'introduire des vulnérabilités ou d'affaiblir le niveau de protection du système.

L'audit de conformité vise quant à lui à vérifier que les configurations mises en œuvre respectent les exigences des référentiels retenus, notamment la loi n°05-20, les recommandations de la DGSSI, les exigences de la DNSSI ainsi que les CIS Benchmarks.

Dans le cadre de ce projet, ces deux approches sont complémentaires. L'audit de configuration permet d'identifier les paramètres à corriger, tandis que l'audit de conformité mesure le niveau de respect des exigences de sécurité définies par les différents référentiels.

1.4 Problématique

Face à l'évolution constante des cybermenaces, les organisations doivent veiller à ce que leurs actifs informatiques soient configurés conformément aux exigences de sécurité et aux bonnes pratiques afin de limiter les risques de compromission.

L'évaluation préliminaire des actifs étudiés a mis en évidence un niveau de maturité « Reproductible » (tableau 1.1), caractérisé par des pratiques de sécurité appliquées de manière partielle. Dans ce contexte, ce projet vise à améliorer le niveau de sécurité des actifs Windows 11 et FortiGate en mettant en œuvre des mesures de durcissement conformes à la loi n°05-20, aux recommandations de la DGSSI, à la DNSSI et aux CIS Benchmarks, afin de faire évoluer leur niveau de maturité vers le niveau « Défini ».

Tableau 1.1 – Niveaux de maturité de la mise en œuvre des contrôles de sécurité

Niveau	Description
Aucun	Aucune mesure de sécurité n'est mise en œuvre.
Initial	Des actions ponctuelles sont réalisées de manière non structurée.
Reproductible	Les actions sont formalisées mais leur exécution reste manuelle.
Défini	Les processus sont standardisés et documentés.
Maîtrise	Les processus sont mesurés et contrôlés de manière proactive.
Optimisé	Les processus font l'objet d'une amélioration continue.

Ainsi, la problématique de ce projet peut être formulée comme suit :

> Comment renforcer le niveau de sécurité des actifs étudiés afin de faire évoluer leur niveau de maturité de « Reproductible » vers « Défini », conformément aux exigences de la loi n°05-20, de la DGSSI, de la DNSSI et des CIS Benchmarks ?

1.5 Objectifs

L'objectif principal de ce projet est de réaliser un audit de configuration et un audit de conformité de deux actifs critiques du système d'information, à savoir le poste de travail Windows 11 et le pare-feu FortiGate, puis de mettre en œuvre les mesures de durcissement nécessaires afin de renforcer leur niveau de sécurité.

Pour atteindre cet objectif, le projet consiste à :

- étudier les référentiels de sécurité applicables, notamment la loi n°05-20, les recommandations de la DGSSI, la DNSSI et les CIS Benchmarks ;
- élaborer des guides d'audit et des checklists de conformité ;
- réaliser un audit initial des configurations afin d'identifier les écarts de sécurité ;
- appliquer les mesures de durcissement recommandées ;
- automatiser certaines opérations à l'aide de scripts ;
- effectuer un audit final permettant d'évaluer l'efficacité des actions mises en œuvre et l'amélioration du niveau de maturité des actifs étudiés.

1.6 Organisation du document

Ce document est organisé en trois chapitres. Le présent chapitre pose le contexte, la problématique et les objectifs. Le chapitre 2 présente les actifs étudiés, les référentiels de sécurité retenus ainsi que l'élaboration des guides et des checklists d'audit. Le chapitre 3 détaille la mise en œuvre du durcissement de Windows 11 et du pare-feu FortiGate, ainsi que la validation des résultats. Une conclusion générale et des perspectives terminent le document.

Chapitre 2

Élaboration des guides et des checklists d'audit des actifs de sécurité

2.1 Introduction

Après avoir présenté le contexte, la problématique et les objectifs du projet, ce chapitre est consacré aux actifs étudiés ainsi qu'à l'élaboration des guides et des checklists d'audit qui serviront de référence pour l'évaluation de leur niveau de sécurité.

L'étude porte sur deux actifs critiques d'un système d'information : le poste de travail Windows 11 et le pare-feu FortiGate. Les guides et les checklists ont été élaborés en s'appuyant sur les exigences de la loi n°05-20, des directives de la DGSSI, de la DNSSI et des CIS Benchmarks, afin de garantir une approche conforme aux bonnes pratiques et aux exigences réglementaires.

Ce chapitre présente tout d'abord les actifs étudiés, puis les principaux référentiels de sécurité retenus. Il décrit ensuite la méthodologie adoptée pour élaborer les guides et les checklists d'audit, qui constituent la base des opérations d'audit et de durcissement présentées dans le chapitre suivant.

2.2 Présentation des actifs étudiés

2.2.1 Windows 11

Présentation

Windows 11 est le système d'exploitation développé par Microsoft et lancé officiellement en octobre 2021. Il constitue la dernière génération des systèmes Windows destinés aux postes de travail et est largement adopté par les entreprises grâce à ses performances, son interface modernisée et ses fonctionnalités avancées de sécurité. Dans un environnement bancaire, il est utilisé sur les postes des collaborateurs afin d'assurer l'exécution des applications métiers, la gestion des données et l'accès sécurisé aux ressources du système d'information.

Rôle dans le système d'information

Le poste de travail Windows 11 représente l'un des principaux points d'accès au système d'information de l'entreprise. Les utilisateurs s'y authentifient pour accéder aux applications internes, aux services réseau et aux ressources partagées. En raison de son exposition aux attaques telles que les logiciels malveillants, le phishing ou les accès non autorisés, il constitue un actif critique nécessitant une configuration de sécurité conforme aux bonnes pratiques et aux exigences réglementaires.

Fonctionnalités de sécurité natives

Windows 11 intègre plusieurs fonctionnalités de sécurité natives permettant de protéger les données et les utilisateurs :

- chiffrement des disques avec BitLocker ;
- antivirus Microsoft Defender ;
- pare-feu Windows Defender Firewall ;
- contrôle des applications ;
- gestion des mises à jour via Windows Update ;
- authentification biométrique avec Windows Hello ;
- journalisation des événements de sécurité.

Ces fonctionnalités constituent la base des opérations d'audit et de durcissement réalisées dans ce projet.

2.2.2 Pare-feu FortiGate

Présentation

FortiGate est un pare-feu nouvelle génération (*Next Generation Firewall*, NGFW) développé par Fortinet. Il assure la protection périmétrique du système d'information en contrôlant les flux réseau entrants et sortants. Grâce à ses nombreuses fonctionnalités de sécurité, il est largement utilisé dans les organisations et particulièrement dans le secteur bancaire, où la protection des infrastructures réseau constitue un enjeu majeur.

Rôle dans la sécurité périmétrique

Le pare-feu FortiGate constitue la première ligne de défense entre le réseau interne de l'entreprise et les réseaux externes, notamment Internet. Il permet :

- de filtrer le trafic réseau ;
- d'appliquer les politiques de sécurité ;
- de contrôler les accès entre les différentes zones réseau ;
- de détecter et bloquer les attaques ;
- de sécuriser les connexions VPN ;
- de centraliser les journaux de sécurité.

Son rôle est essentiel pour assurer la disponibilité, l'intégrité et la confidentialité des communications.

Architecture

L'architecture d'un pare-feu FortiGate (figure 2.1) est généralement composée des éléments suivants :

- interface WAN ;
- interface LAN ;
- moteur de filtrage ;
- moteur IPS (*Intrusion Prevention System*) ;
- antivirus ;
- contrôle applicatif ;
- filtrage Web ;
- VPN IPsec et SSL ;
- journalisation et supervision.

Ces composants travaillent conjointement afin d'assurer une protection complète du réseau.

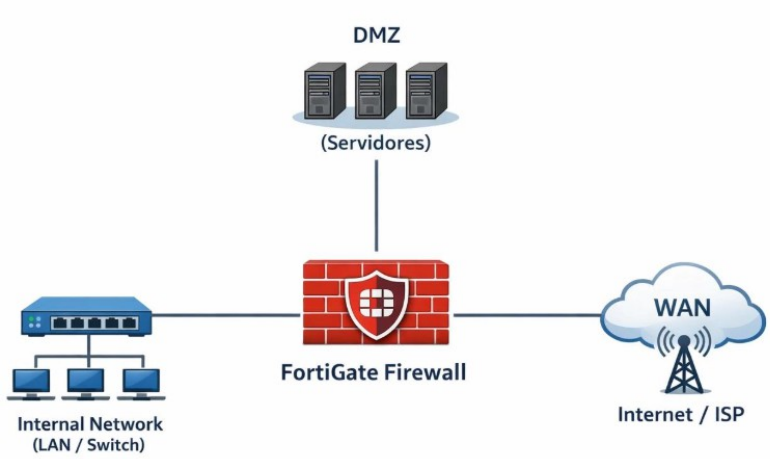


Figure 2.1 – Architecture générale d'un pare-feu FortiGate

Fonctionnalités principales

FortiGate offre de nombreuses fonctionnalités de sécurité, notamment :

- pare-feu nouvelle génération (NGFW) ;
- système de prévention des intrusions (IPS) ;
- antivirus ;
- filtrage Web ;
- contrôle des applications ;
- inspection SSL ;
- VPN IPsec et SSL VPN ;
- authentification des utilisateurs ;
- journalisation et génération de rapports ;
- haute disponibilité (HA).

Ces fonctionnalités permettent de répondre aux exigences de sécurité des infrastructures critiques et servent de base aux opérations d'audit et de durcissement présentées dans le chapitre suivant.

2.3 Présentation des référentiels de sécurité

Afin de garantir une démarche d'audit conforme aux bonnes pratiques et aux exigences réglementaires, plusieurs référentiels de sécurité ont été retenus. Ces référentiels constituent la base de l'élaboration des guides et des checklists d'audit utilisés pour évaluer la sécurité des actifs étudiés.

2.3.1 Loi n°05-20

La loi n°05-20 relative à la cybersécurité établit le cadre juridique marocain visant à renforcer la protection des systèmes d'information des administrations publiques, des organismes sensibles et des opérateurs d'importance vitale. Elle définit les principes généraux de gouvernance de la cybersécurité, les obligations en matière de protection des systèmes d'information ainsi que les exigences liées à la gestion des risques et des incidents de sécurité. Dans le cadre de ce projet, cette loi constitue une référence réglementaire pour l'identification des exigences de sécurité applicables aux actifs étudiés.

2.3.2 Direction Générale de la Sécurité des Systèmes d'Information (DGSSI)

La Direction Générale de la Sécurité des Systèmes d'Information (DGSSI) est l'autorité nationale chargée de la cybersécurité au Maroc. Elle élabore des politiques, des guides et des recommandations destinés à améliorer le niveau de sécurité des systèmes d'information des organismes publics et privés. Les guides publiés par la DGSSI ont servi de référence pour sélectionner plusieurs mesures de sécurité intégrées aux guides et aux checklists d'audit élaborés dans ce projet.

2.3.3 Directive Nationale de la Sécurité des Systèmes d'Information (DNSSI)

La Directive Nationale de la Sécurité des Systèmes d'Information (DNSSI) définit les exigences minimales de sécurité que les organismes concernés doivent appliquer afin d'assurer la protection de leurs systèmes d'information. Elle couvre notamment la gouvernance de la sécurité, la gestion des accès, la protection des infrastructures, la gestion des vulnérabilités et la journalisation. Les recommandations de la DNSSI ont été utilisées pour compléter les contrôles de conformité appliqués aux actifs étudiés.

2.3.4 CIS Benchmarks

Les CIS Benchmarks, publiés par le Center for Internet Security (CIS), constituent un ensemble de recommandations internationales destinées au durcissement des systèmes d'exploitation, des équipements réseau et des applications. Ils proposent des paramètres de configuration permettant de réduire la surface d'attaque et de renforcer la sécurité des actifs informatiques. Dans ce projet, les CIS Benchmarks relatifs à Windows 11 et au pare-feu FortiGate ont constitué la principale référence technique pour l'élaboration des guides, des checklists d'audit et des mesures de durcissement.

2.4 Méthodologie d'élaboration des guides

L'élaboration des guides d'audit et des checklists de conformité a suivi une démarche structurée en plusieurs étapes :

1. **Analyse des référentiels** : étude approfondie des exigences issues de la loi n°05-20, des guides de la DGSSI, de la DNSSI et des CIS Benchmarks ;
2. **Sélection des exigences** : identification des contrôles pertinents au regard du contexte bancaire et de l'environnement technique du laboratoire ;
3. **Comparaison des exigences** : mise en correspondance des recommandations issues des différents référentiels afin d'éviter les redondances et d'identifier les éventuels écarts ;
4. **Regroupement par domaine** : classification des contrôles retenus par domaine fonctionnel (authentification, chiffrement, journalisation, réseau, etc.) ;
5. **Élaboration des guides** : rédaction des guides détaillant chaque contrôle, sa justification ainsi que la configuration recommandée ;
6. **Élaboration des checklists** : synthèse des guides sous forme de checklists exploitables lors des opérations d'audit.

2.5 Guide d'audit Windows 11

2.5.1 Objectif du guide

Dans le cadre de ce projet, un guide d'audit de sécurité a été élaboré afin de disposer d'un document de référence permettant d'évaluer la conformité de la configuration du système d'exploitation Windows 11. Ce guide constitue une base méthodologique pour les opérations d'audit et de durcissement en regroupant les principaux contrôles de sécurité applicables au poste de travail.

Son élaboration repose principalement sur les recommandations des CIS Benchmarks Windows 11 Enterprise et du guide de durcissement de la DNSSI. Les exigences de la loi n°05-20 ainsi que les orientations de la DGSSI ont également été prises en compte afin d'assurer la conformité avec le cadre réglementaire marocain.

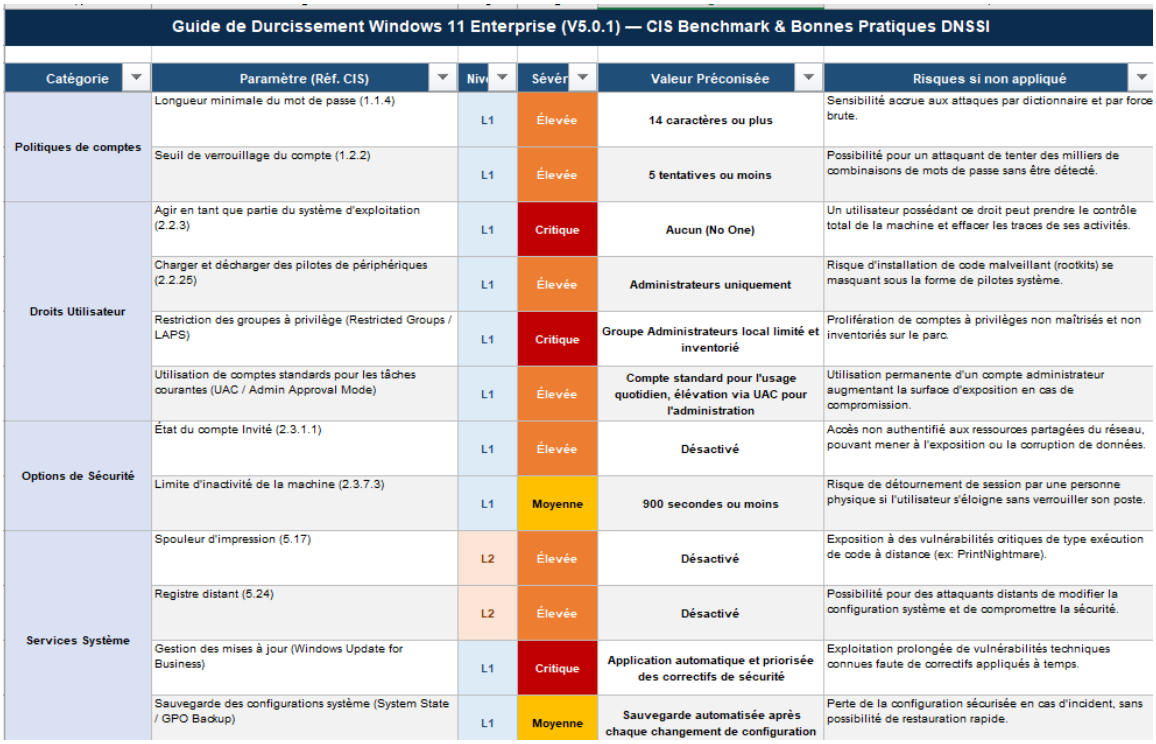
2.5.2 Structure du guide

Le guide est structuré autour de plusieurs domaines de sécurité couvrant les principaux paramètres de configuration de Windows 11. Parmi les domaines étudiés figurent notamment :

- gestion des comptes et authentification ;
- politique des mots de passe ;
- stratégies de sécurité locales ;
- droits des utilisateurs ;
- Microsoft Defender Antivirus ;
- pare-feu Microsoft Defender ;
- chiffrement BitLocker ;
- journalisation et audit ;
- services Windows ;
- configuration réseau ;
- paramètres système.

Pour chaque contrôle, le guide précise la référence du contrôle, la configuration recommandée,

le niveau de sévérité ainsi que le référentiel utilisé. La figure 2.2 présente un extrait du guide d'audit de Windows 11.



Guide de Durcissement Windows 11 Enterprise (V5.0.1) — CIS Benchmark & Bonnes Pratiques DNSSI

Catégorie	Paramètre (Réf. CIS)	Niv	Sévér	Valeur Préconisée	Risques si non appliqué
Politiques de comptes	Longueur minimale du mot de passe (1.1.4)	L1	Élevée	14 caractères ou plus	Sensibilité accrue aux attaques par dictionnaire et par force brute.
	Seuil de verrouillage du compte (1.2.2)	L1	Élevée	5 tentatives ou moins	Possibilité pour un attaquant de tenter des milliers de combinaisons de mots de passe sans être détecté.
Droits Utilisateur	Agir en tant que partie du système d'exploitation (2.2.3)	L1	Critique	Aucun (No One)	Un utilisateur possédant ce droit peut prendre le contrôle total de la machine et effacer les traces de ses activités.
	Charger et décharger des pilotes de périphériques (2.2.25)	L1	Élevée	Administrateurs uniquement	Risque d'installation de code malveillant (rootkits) se masquant sous la forme de pilotes système.
	Restriction des groupes à privilège (Restricted Groups / LAPS)	L1	Critique	Groupe Administrateurs local limité et inventorié	Prolifération de comptes à privilèges non maîtrisés et non inventoriés sur le parc.
	Utilisation de comptes standards pour les tâches courantes (UAC / Admin Approval Mode)	L1	Élevée	Compte standard pour l'usage quotidien, élévation via UAC pour l'administration	Utilisation permanente d'un compte administrateur augmentant la surface d'exposition en cas de compromission.
Options de Sécurité	État du compte Invité (2.3.1.1)	L1	Élevée	Désactivé	Accès non authentifié aux ressources partagées du réseau, pouvant mener à l'exposition ou la corruption de données.
	Limite d'inactivité de la machine (2.3.7.3)	L1	Moyenne	900 secondes ou moins	Risque de détournement de session par une personne physique si l'utilisateur s'éloigne sans verrouiller son poste.
Services Système	Spouleur d'impression (5.17)	L2	Élevée	Désactivé	Exposition à des vulnérabilités critiques de type exécution de code à distance (ex: PrintNightmare).
	Registre distant (5.24)	L2	Élevée	Désactivé	Possibilité pour des attaquants distants de modifier la configuration système et de compromettre la sécurité.
	Gestion des mises à jour (Windows Update for Business)	L1	Critique	Application automatique et priorisée des correctifs de sécurité	Exploitation prolongée de vulnérabilités techniques connues faute de correctifs appliqués à temps.
	Sauvegarde des configurations système (System State / GPO Backup)	L1	Moyenne	Sauvegarde automatisée après chaque changement de configuration	Perte de la configuration sécurisée en cas d'incident, sans possibilité de restauration rapide.

Figure 2.2 – Extrait du guide d'audit de Windows 11

2.6 Guide d'audit FortiGate

2.6.1 Objectif du guide

Afin d'évaluer la sécurité de la configuration du pare-feu FortiGate, un guide d'audit spécifique a été élaboré. Ce document rassemble les principaux contrôles permettant de vérifier la conformité des paramètres de sécurité et de préparer les opérations de durcissement.

Le guide est principalement basé sur le CIS Benchmark FortiGate 7.0.x ainsi que sur le guide de durcissement de la DNSSI. Les exigences de la loi n°05-20 et les recommandations de la DGSSI ont également été prises en considération afin d'assurer la conformité avec les exigences nationales.

2.6.2 Structure du guide

Le guide est organisé selon les principaux domaines de configuration du pare-feu, notamment :

- gestion des comptes administrateurs ;
- authentification et contrôle d'accès ;
- configuration des interfaces ;
- politiques de sécurité (*firewall policies*) ;
- services réseau ;
- VPN ;
- journalisation et supervision ;
- sauvegarde et restauration de la configuration ;
- administration sécurisée.

Pour chaque contrôle, le guide indique la configuration recommandée, le niveau de sévérité, les risques associés ainsi que le référentiel de sécurité correspondant. La figure 2.3 présente un extrait de ce guide.

GUIDE DE DURCISSEMENT FORTIGATE 7.0.x — ALIGNEMENT SUR LA DIRECTIVE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (DNSSI v2 - 2023)

Sources : CIS Fortigate 7.0.x Benchmark v1.4.0 (Center for Internet Security) et Directive Nationale de la Sécurité des Systèmes d'Information, version n.2 - 2023 (DGSSI, Royaume du Maroc). Sévérité dérivée des niveaux CIS Implementation Group (IG1/IG2/IG3).

N° R… Cl…	Catégorie	Paramètre	Nive… (Profil …	Séve…	Valeur préconisée	Risque si non appliquée
1.2	**Sécurité des communications**	Interdiction du trafic intra-zone par défaut	Level 1	**Moyen**	Positionner 'intrazone' sur 'deny' pour chaque zone réseau sensible (ex. DMZ) afin de forcer l'inspection du trafic inter-interfaces.	Propagation latérale non contrôlée d'une attaque entre systèmes d'une même zone, sans inspection ni journalisation.
1.3	**Contrôle d'accès**	Services d'administration désactivés sur l'interface WAN	Level 1	**Critique**	Désactiver HTTPS, HTTP, PING, SSH, SNMP et Radius sur les interfaces WAN ; réserver l'administration à l'interface de management dédiée.	Exposition de l'interface d'administration sur Internet, augmentant fortement la surface d'attaque et le risque de prise de contrôle du pare-feu.
2.1.1	**Gestion des actifs informationnels**	Bannière de pré-connexion (Pre-Login Banner) activée	Level 1	**Critique**	Activer 'pre-login-banner' et diffuser un avertissement légal rappelant le caractère restreint de l'accès au système.	Absence d'avertissement légal réduisant la portée des poursuites en cas d'accès non autorisé et affaiblissant l'opposabilité de la charte d'utilisation.
2.1.2	**Gestion des actifs informationnels**	Bannière de post-connexion (Post-Login Banner) activée	Level 1	**Élevé**	Activer 'post-login-banner' avec un message rappelant les obligations de confidentialité et de surveillance après authentification.	Défaut de sensibilisation de l'administrateur connecté sur ses responsabilités, affaiblissant la traçabilité juridique des actions.
2.1.3	**Sécurité liée à l'exploitation**	Fuseau horaire correctement configuré	Level 1	**Élevé**	Configurer le fuseau horaire réel du site d'exploitation (ex. 'set timezone <ID>').	Horodatage incohérent des journaux et des certificats, rendant difficile la corrélation d'événements lors d'un incident.
2.1.4	**Sécurité liée à l'exploitation**	Synchronisation horaire via NTP de confiance	Level 1	**Élevé**	Configurer un serveur NTP interne ou de confiance (type 'custom') en primaire et secondaire, plutôt que le NTP FortiGuard par défaut.	Dérive de l'horloge système compromettant la fiabilité des journaux, l'investigation post-incident et la validité des certificats.
2.1.5	**Gestion des actifs informationnels**	Nom d'hôte (hostname) personnalisé et explicite	Level 1	**Faible**	Remplacer le nom d'hôte par défaut (modèle du boîtier) par un nom conforme à la convention de nommage de l'entité.	Difficulté d'identification de l'équipement dans l'inventaire des actifs et dans la corrélation des journaux multi-systèmes.
2.1.6	**Sécurité liée à l'exploitation**	Dernier firmware (correctifs) installé	Level 2	**Critique**	Appliquer la trajectoire de mise à niveau recommandée par Fortinet et maintenir le firmware à la dernière version stable qualifiée.	Exploitation de vulnérabilités connues et non corrigées, exposant le pare-feu à une compromission via des exploits publics.
2.1.7	**Gestion des actifs informationnels**	Installation USB de firmware/configuration désactivée	Level 2	**Élevé**	Désactiver 'auto-install-config' et 'auto-install-image' (config system auto-install).	Chargement automatique d'une configuration ou d'un firmware falsifié via un support USB connecté physiquement, sans contrôle.
2.1.8	**Cryptographie**	Clés statiques TLS désactivées	Level 2	**Élevé**	Désactiver 'ssl-static-key-ciphers' (config system global).	Utilisation de clés de chiffrement statiques facilitant le déchiffrement rétroactif des sessions TLS interceptées.

Figure 2.3 – Extrait du guide d'audit du pare-feu FortiGate

2.7 Élaboration des checklists d'audit

2.7.1 Objectif des checklists

À partir des guides d'audit élaborés pour Windows 11 et le pare-feu FortiGate, des checklists d'audit ont été développées afin de faciliter les opérations de vérification de la conformité des configurations de sécurité. Ces checklists constituent un outil pratique permettant de contrôler de manière systématique chaque exigence de sécurité et de consigner les résultats de l'audit.

Chaque contrôle est associé à un statut permettant d'indiquer s'il est conforme, non conforme ou non applicable, ce qui facilite l'identification des écarts de configuration ainsi que le suivi des actions correctives.

2.7.2 Structure des checklists

Chaque checklist reprend, sous une forme condensée, l'ensemble des contrôles détaillés dans le guide d'audit correspondant. Elle se présente sous la forme d'un tableau structuré autour

de deux colonnes principales : la description du contrôle à vérifier et le statut de conformité observé, ce dernier étant décliné en trois modalités : *Conforme*, *Non conforme* et *Non applicable* (N/A).

Cette structure uniforme, reprise pour chaque actif étudié, permet de faciliter la lecture des résultats d'audit, d'homogénéiser la démarche de vérification entre les différents actifs et de simplifier la consolidation des écarts de conformité en vue de la définition des actions de durcissement.

2.7.3 Utilisation des checklists

Les checklists ont été utilisées tout au long des opérations d'audit afin d'évaluer le niveau de conformité des actifs étudiés. Elles ont permis d'identifier les paramètres de configuration non conformes aux recommandations des référentiels de sécurité et de préparer les opérations de durcissement présentées dans le chapitre suivant.

Les résultats obtenus à l'aide de ces checklists constituent la base de l'analyse des écarts de sécurité et des recommandations formulées dans ce projet.

2.7.4 Checklist Windows 11

La figure 2.4 présente un extrait de la checklist d'audit élaborée pour le poste de travail Windows 11.

Check-list de Vérification — Guide de Durcissement Windows 11 Enterprise (CIS & DNSSI)

Catégorie	Paramètre (Réf. CIS)	Niv	Sévé	Valeur Préconisée	Statut c conform	Constat / Remarque
Politiques de comptes	Longueur minimale du mot de passe (1.1.4)	L1	Élevée	14 caractères ou plus	Non évalué	
	Seuil de verrouillage du compte (1.2.2)	L1	Élevée	5 tentatives ou moins	Non évalué	
Droits Utilisateur	Agir en tant que partie du système d'exploitation (2.2.3)	L1	Critique	Aucun (No One)	Non évalué	
	Charger et décharger des pilotes de périphériques (2.2.25)	L1	Élevée	Administrateurs uniquement	Non évalué	
	Restriction des groupes à privilège (Restricted Groups / LAPS)	L1	Critique	Groupe Administrateurs local limité et inventorié	Non évalué	
	Utilisation de comptes standards pour les tâches courantes (UAC / Admin Approval Mode)	L1	Élevée	Compte standard pour l'usage quotidien, élévation via UAC pour l'administration	Non évalué	
Options de Sécurité	État du compte Invité (2.3.1.1)	L1	Élevée	Désactivé	Non évalué	
	Limite d'inactivité de la machine (2.3.7.3)	L1	Moyenne	900 secondes ou moins	Non évalué	
Services Système	Spouleur d'impression (5.17)	L2	Élevée	Désactivé	Non évalué	
	Registre distant (5.24)	L2	Élevée	Désactivé	Non évalué	
	Gestion des mises à jour (Windows Update for Business)	L1	Critique	Application automatique et priorisée des correctifs de sécurité	Non évalué	
	Sauvegarde des configurations système (System State / GPO Backup)	L1	Moyenne	Sauvegarde automatisée après chaque changement de configuration	Non évalué	
Pare-feu Windows	État du pare-feu (Profil Domaine/Privé/Public) (9.1.1)	L1	Critique	Activé	Non évalué	
Audit Avancé	Audit de la validation des informations d'identification (17.1.1)	L1	Moyenne	Succès et Échec	Non évalué	
	Synchronisation de l'horloge système (service Windows Time - w32time)	L1	Moyenne	Source NTP fiable et synchronisée	Non évalué	
	Taille et rétention des journaux d'événements (Event Log)	L1	Élevée	Taille maximale augmentée, rétention ≥ 6 mois ou	Non évalué	

Figure 2.4 – Extrait de la checklist d'audit Windows 11

2.7.5 Checklist du pare-feu FortiGate

La figure 2.5 présente un extrait de la checklist d'audit élaborée pour le pare-feu FortiGate.

CHECKLIST DE CONFORMITÉ — DURCISSEMENT FORTIGATE 7.0.x (CIS Benchmark) ALIGNÉ DNSSI v2 (2023)

Entité / IIV : _____ Date de l'audit : _____ Auditeur / Responsable SSI : _____

	Domaine DNSSI	Paramètre à vérifier	Nive	Sévér	Statut de conform	Date de vérificatio	Vérifié pa	Preuve / Action corrective
1	Sécurité des communications	Serveur DNS de confiance configuré	Level 1	Élevé	À vérifier			
2	Sécurité des communications	Interdiction du trafic intra-zone par défaut	Level 1	Moyen	À vérifier			
3	Contrôle d'accès	Services d'administration désactivés sur l'interface WAN	Level 1	Critique	À vérifier			
4	Gestion des actifs informationnels	Bannière de pré-connexion (Pre-Login Banner) activée	Level 1	Critique	À vérifier			
5	Gestion des actifs informationnels	Bannière de post-connexion (Post-Login Banner) activée	Level 1	Élevé	À vérifier			
6	Sécurité liée à l'exploitation	Fuseau horaire correctement configuré	Level 1	Élevé	À vérifier			
7	Sécurité liée à l'exploitation	Synchronisation horaire via NTP de confiance	Level 1	Élevé	À vérifier			
8	Gestion des actifs informationnels	Nom d'hôte (hostname) personnalisé et explicite	Level 1	Faible	À vérifier			
9	Sécurité liée à l'exploitation	Dernier firmware (correctifs) installé	Level 2	Critique	À vérifier			
10	Gestion des actifs informationnels	Installation USB de firmware/configuration désactivée	Level 2	Élevé	À vérifier			
11	Cryptographie	Clés statiques TLS désactivées	Level 2	Élevé	À vérifier			
12	Cryptographie	Chiffrement fort global activé (Strong Encryption)	Level 2	Faible	À vérifier			
13	Cryptographie	GUI d'administration limitée à TLS 1.2/1.3	Level 1	Faible	À vérifier			
14	Hors périmètre direct DNSSI (performance)	CDN activé pour les ressources statiques de la GUI	Level 2	Faible	À vérifier			
15	Sécurité liée à l'exploitation	Journalisation de la surcharge d'un cœur CPU unique	Level 1	Faible	À vérifier			
16	Contrôle d'accès	Politique de mots de passe robustes activée	Level 1	Élevé	À vérifier			
17	Contrôle d'accès	Verrouillage après tentatives échouées configuré	Level 1	Critique	À vérifier			

Figure 2.5 – Extrait de la checklist d'audit FortiGate

2.8 Conclusion

Ce chapitre a présenté les deux actifs étudiés, le poste de travail Windows 11 et le pare-feu FortiGate, ainsi que la méthodologie suivie pour élaborer leurs guides et checklists d'audit, à partir des référentiels retenus (loi n°05-20, DGSSI, DNSSI, CIS Benchmarks). Après analyse et sélection des exigences pertinentes regroupées par domaine, des guides détaillant chaque contrôle ont été rédigés, puis synthétisés en checklists (Conforme, Non conforme, N/A) servant de base aux opérations d'audit et de durcissement présentées dans le chapitre suivant.

Chapitre 3

Mise en œuvre du durcissement et validation des résultats

3.1 Introduction

Ce chapitre présente la mise en œuvre des opérations d'audit, de durcissement et de validation des deux actifs étudiés, à savoir le poste de travail Windows 11 et le pare-feu FortiGate. Après une présentation de l'environnement de test, les différentes étapes réalisées pour chaque actif sont décrites, depuis l'évaluation de l'état initial jusqu'à la validation des mesures de sécurité mises en œuvre. Les résultats obtenus sont ensuite analysés afin d'évaluer l'efficacité des actions de durcissement et leur contribution au renforcement du niveau de sécurité.

3.2 Présentation de l'environnement de test

Les opérations d'audit, de durcissement et de validation ont été réalisées dans un environnement virtualisé sous VMware Workstation 17 Pro. Cet environnement a permis de déployer les différentes machines virtuelles nécessaires à la mise en œuvre des tests de sécurité et des opérations de durcissement. Les principales caractéristiques de l'environnement sont présentées dans le tableau 3.1.

Tableau 3.1 – Environnement de test

Élément	Description
Machine hôte	Windows 10 Enterprise, version 22H2 (Build 19045.6456)
Plateforme de virtualisation	VMware Workstation 17 Pro
Machine virtuelle cible	Windows 11
Machine virtuelle d'attaque	Kali Linux
Équipement de sécurité	Pare-feu FortiGate VM
Outils de test	Hydra, Nmap
Outils de durcissement	Scripts PowerShell, stratégies de sécurité Windows, interface d'administration FortiGate
Validation	Rapports HTML générés avant et après le durcissement

3.3 Durcissement du poste Windows 11

3.3.1 Audit initial

Avant la mise en œuvre des mesures de durcissement, un audit de sécurité a été réalisé sur le poste Windows 11 afin d'évaluer son niveau de conformité par rapport aux recommandations du CIS Microsoft Windows 11 Benchmark ainsi qu'aux exigences du référentiel de la Direction Générale de la Sécurité des Systèmes d'Information (DGSSI). Cette étape a permis d'identifier les écarts de configuration et les vulnérabilités susceptibles d'affecter la sécurité du système.

La figure 3.1 présente le tableau de bord du rapport HTML généré avant l'application des mesures de durcissement.



Figure 3.1 – Tableau de bord du rapport d'audit avant le durcissement du poste Windows 11

L'analyse du tableau de bord montre que 40 paramètres de sécurité ont été évalués. Parmi ceux-ci, 10 sont conformes, 20 sont non conformes et 10 nécessitent une vérification manuelle, ce qui correspond à un taux de conformité initial de 25 %. Ce résultat met en évidence plusieurs insuffisances de configuration qui nécessitent la mise en œuvre de mesures de durcissement.

Afin d'identifier précisément les paramètres concernés, le rapport fournit également le détail des contrôles évalués, comme illustré par la figure 3.2.

Analyse des résultats

L'analyse détaillée des résultats montre que plusieurs catégories de paramètres présentent des non-conformités susceptibles d'affecter la sécurité du poste Windows 11. Les principales concernent la gestion des services système, les mécanismes d'audit, le contrôle des applications (AppLocker), la gestion des comptes, les protections avancées (VBS et HVCI), le chiffrement des données avec BitLocker, ainsi que certains paramètres de protection réseau et de confidentialité.

À l'inverse, plusieurs contrôles essentiels sont déjà conformes, notamment la désactivation du compte Invité, l'activation du pare-feu Windows sur l'ensemble des profils, la désactivation de SMBv1 et la protection en temps réel de Microsoft Defender.

Par ailleurs, certains contrôles sont classés en « Vérification manuelle », car leur validation dépend d'une infrastructure externe telle qu'Active Directory, une solution IAM, MDM ou PKI. Ces paramètres n'ont pas pu être évalués dans le cadre de l'environnement de test utilisé.

Globalement, l'audit met en évidence un taux de conformité initial de 25 %, révélant un niveau de sécurité insuffisant au regard des recommandations du CIS Benchmark et de la DGSSI. Ces résultats justifient la mise en œuvre des opérations de durcissement présentées dans les sections suivantes.

Résultats détaillés de l'audit CIS – Poste de travail Windows 11 (avant durcissement)

Catégorie	Paramètre (Réf. CIS)	Niveau	Sévérité	Valeur préconisée	Valeur constatée	Statut	Remarque
Politiques de comptes	Longueur minimale du mot de passe (1.4)	L1	Élevée	14 caractères ou plus	0 caractère	Non conforme	-
Politiques de comptes	Seuil de verrouillage du compte (1.2.2)	L1	Élevée	5 tentatives ou moins	10 tentative(s)	Non conforme	-
Droits Utilisateur	Agir en tant que partie du système d'exploitation (2.2.3)	L1	Critique	Aucun (No One)	Aucun	Conforme	-
Droits Utilisateur	Charger et décharger des pilotes de périphériques (2.2.25)	L1	Élevée	Administrateurs uniquement	*S-1-5-32-544	Conforme	-
Droits Utilisateur	Restriction des groupes à privilège (Restricted Groups / LAPS)	L1	Critique	Groupe Administrateurs local limité et inventorié	2 membre(s): user \Administrateur; user \audit	Conforme	-
Droits Utilisateur	Utilisation de comptes standards pour les tâches courantes (UAC / Admin Approval Mode)	L1	Élevée	Compte standard pour l'usage quotidien, élévation via UAC	UAC activé	Conforme	-
Options de Sécurité	État du compte Invité (2.3.1.1)	L1	Élevée	Désactivé	Désactivé	Conforme	-
Options de Sécurité	Limite d'inactivité de la machine (2.3.7.3)	L1	Moyenne	900 secondes ou moins	Non configuré	Non conforme	-
Services Système	Spouleur d'impression (5.17)	L2	Élevée	Désactivé	Running / Démarrage: Automatic	Non conforme	-
Services Système	Registre distant (5.24)	L2	Élevée	Désactivé	Running / Démarrage: Automatic	Non conforme	-
Services Système	Gestion des mises à jour (Windows Update for Business)	L1	Critique	Application automatique et priorisée des correctifs de sécurité	Stratégie non configurée localement	Non conforme	-
Services Système	Sauvegarde des configurations système (System State / GPO Backup)	L1	Moyenne	Sauvegarde automatisée après chaque changement de configuration	Non vérifiable localement	Manuel	Vérifier la procédure de sauvegarde auprès de l'équipe infrastructure
Pare-feu Windows	État du pare-feu (Profil Domaine/Privé/Public) (9.1.1)	L1	Critique	Activé	Domain: Activé | Private: Activé | Public: Activé	Conforme	-
Audit Avancé	Audit de la validation des informations d'identification (17.1.1)	L1	Moyenne	Succès et Échec	Non configuré	Non conforme	-
Audit Avancé	Synchronisation de l'horloge système (service Windows Time - w32time)	L1	Moyenne	Actif	Stopped / Démarrage: Manual	Non conforme	-
Audit Avancé	Taille et rétention des journaux d'événements (Event Log)	L1	Élevée	Taille maximale augmentée, rétention ≥ 6 mois ou centralisation SIEM	Journal Sécurité: 20 Mo	Non conforme	-
Modèles d'admin.	Exécution automatique - AutoRun (18.10.8.2)	L1	Élevée	Ne pas exécuter	Non configuré	Non conforme	-
Modèles d'admin.	Restriction d'installation des logiciels (AppLocker / Restrictions logicielles)	L2	Élevée	Liste blanche d'applications autorisées	0 règle(s) AppLocker active(s)	Non conforme	-
Accès & Comptes	Renommer le compte administrateur (2.3.1.3)	L1	Moyenne	Nom non générique	Nom actuel: Administrateur	Non conforme	-
Accès & Comptes	Restriction des plages horaires de connexion (Logon Hours)	L2	Moyenne	Connexions limitées aux plages horaires métier définies	Dépend de la configuration Active Directory / Entra ID	Manuel	À vérifier dans les propriétés des comptes AD
Accès & Comptes	Revue périodique des comptes et détection des doublons (audit AD / Entra ID)	L2	Moyenne	Revue au moins annuelle des comptes actifs et des identifiants redondants	Non vérifiable localement	Manuel	À vérifier auprès de l'équipe IAM
Système & VBS	Sécurité basée sur la virtualisation (18.9.5.1)	L1	Critique	Activé	Statut = 0	Non conforme	-
Système & VBS	Protection de l'intégrité du code (18.9.5.3)	L1	Élevée	Activé + Verrou UEFI	HVCI inactif	Non conforme	-
Chiffrement	BitLocker : Récupération (18.10.10.2)	L1+BL	Élevée	Activé	Protection: Off	Non conforme	-
Chiffrement	BitLocker : Écriture sur supports amovibles (18.10.10.3.14)	L1+BL	Élevée	Activé	Stratégie non configurée	Non conforme	-
Chiffrement	Chiffrement des connexions VPN (tunnelisation)	L1	Élevée	Protocoles VPN chiffrés (IKEv2/TLS uniquement)	Dépend de la configuration de la passerelle VPN	Manuel	À vérifier auprès de l'équipe réseau
Chiffrement	Politique de certificats (durée de validité, algorithme, longueur de clé)	L1	Élevée	Certificats ≤ 1 an, SHA-256 minimum, clé ≥ 2048 bits	Dépend de la PKI / autorité de certification	Manuel	À vérifier auprès de l'équipe PKI
Protection Réseau	SMBv1 Client & Serveur (18.4.2 / 18.4.3)	L1	Élevée	Désactivé	État: Disabled	Conforme	-
Protection Réseau	Résolution de noms Multicast - LLMNR (18.6.4.4)	L1	Élevée	Désactivé	Stratégie non configurée (activé par défaut)	Non conforme	-
Protection Réseau	Sécurisation du Bureau à distance (RDP)	L1	Élevée	Authentification au niveau réseau (NLA) + chiffrement TLS	NLA activée	Conforme	-
Protection Réseau	Sécurisation du télétravail (VPN Always On + accès conditionnel)	L1	Élevée	VPN systématique avec authentification forte et vérification de conformité du poste	Dépend de la solution VPN / Intune déployée	Manuel	À vérifier auprès de l'équipe infrastructure
Protection Réseau	Contrôle des équipements autorisés sur le réseau (802.1X / NAC)	L2	Élevée	Authentification 802.1X obligatoire pour toute connexion filaire/Wi-Fi	Dépend de la config. des commutateurs / contrôleurs Wi-Fi	Manuel	À vérifier auprès de l'équipe réseau
Défense OS	Microsoft Defender : Protection en temps réel (18.10.42.10.3)	L1	Critique	Activé (désactivation impossible)	Protection en temps réel activée	Conforme	-
Défense OS	Microsoft Defender SmartScreen (18.10.77.2.1)	L1	Élevée	Avertir et bloquer	Stratégie non configurée	Non conforme	-
Confidentialité	Synchronisation du presse-papiers (18.9.33.1)	L2	Moyenne	Désactivé	Stratégie non configurée	Non conforme	-
Confidentialité	Publicité et identifiant publicitaire (18.9.51.1)	L2	Faible	Désactivé	Stratégie non configurée	Non conforme	-
Confidentialité	Chiffrement de la messagerie et des pièces jointes sensibles	-	Moyenne	Chiffrement S/MIME activé pour les messages sensibles	Dépend de la config. du client de messagerie / Exchange	Manuel	À vérifier auprès de l'équipe messagerie
Confidentialité	Classification et étiquetage des données (WIP / Microsoft Purview)	-	Moyenne	Étiquetage automatique selon la sensibilité + protection WIP activée	Dépend de la config. Microsoft Purview / Intune	Manuel	À vérifier auprès de l'équipe conformité
Gestion appareils mobiles	Inscription et conformité des postes (MDM / Intune)	L1	Élevée	Postes joints à un MDM avec stratégies de conformité obligatoires	Poste inscrit à un fournisseur MDM	Conforme	-
Gestion des actifs	Inventaire automatisé des postes et logiciels (SCCM / Intune)	L2	Moyenne	Inventaire matériel/logiciel centralisé et mis à jour automatiquement	Non vérifiable localement	Manuel	À vérifier auprès de l'équipe gestion des actifs (SCCM/Intune)

Figure 3.2 – Résultats détaillés de l'audit CIS du poste de travail Windows 11 avant durcissement

3.3.2 Simulation d'une attaque par force brute sur RDP

Afin d'évaluer le niveau de résistance initial du poste Windows 11 face aux tentatives d'authentification répétées, une simulation d'attaque par force brute sur le protocole Remote Desktop Protocol (RDP) a été réalisée dans l'environnement de laboratoire.

L'objectif de cette simulation est de vérifier si un attaquant disposant d'un accès au réseau peut tenter plusieurs combinaisons d'identifiants afin d'obtenir un accès au service RDP. Cette étape est réalisée avant l'application des mesures de durcissement afin d'établir un état initial de sécurité.

La machine Kali Linux a été utilisée comme machine source de l'attaque, tandis que le poste Windows 11 constitue la machine cible. Le service RDP est accessible sur le port TCP 3389.

Préparation de l'attaque

Une liste de mots de passe de test a été préparée dans la machine Kali Linux. La tentative d'authentification a ensuite été réalisée à l'aide de l'outil Hydra, spécialisé dans les tests de résistance des mécanismes d'authentification. La commande utilisée dans le laboratoire est la suivante :

```
hydra -l audit -P passwords.txt rdp://192.168.100.136
```

où :

- `-l audit` désigne le compte utilisateur utilisé pour le test ;
- `-P passwords.txt` indique la liste de mots de passe de test ;
- `rdp://192.168.100.136` désigne le service RDP de la machine Windows 11 cible.

Cette opération a été réalisée exclusivement dans l'environnement de laboratoire mis en place pour l'audit.

Déroulement de la simulation

Lors de l'exécution de la commande, Hydra tente successivement les différents mots de passe présents dans la liste de test. L'outil indique notamment que le service RDP est accessible sur le port TCP 3389 (figures 3.3 et 3.4).



Figure 3.3 – Lancement de la simulation de force brute RDP depuis Kali Linux



Figure 3.4 – Résultat de la simulation d'attaque RDP avec Hydra

Résultats obtenus

La simulation a permis d'identifier les identifiants utilisés pour le compte de test. Hydra indique notamment :

```
[3389][rdp] host: 192.168.100.136
login: audit   password: ********
```

Le résultat montre que le mécanisme d'authentification RDP accepte les identifiants testés. Cette situation met en évidence le risque associé à l'utilisation d'un mot de passe faible ou présent dans une liste de mots de passe connue.

Il convient toutefois de préciser que cette simulation ne constitue pas à elle seule une preuve de compromission complète du poste. Elle démontre principalement la possibilité de réaliser des tentatives d'authentification répétées contre le service RDP lorsque celui-ci est accessible.

Analyse de sécurité

Le résultat obtenu avant durcissement constitue l'état de référence (*baseline*) utilisé pour évaluer l'efficacité des mesures de sécurité appliquées par la suite. Plusieurs mesures de durcissement peuvent être mises en œuvre afin de réduire ce risque, notamment :

- l'utilisation de mots de passe robustes ;
- la limitation des comptes autorisés à utiliser RDP ;
- l'activation de mécanismes de protection contre les tentatives d'authentification répétées ;
- la restriction de l'accès au service RDP aux réseaux ou adresses IP autorisés ;
- l'activation de mécanismes de journalisation et de surveillance des connexions RDP ;
- la désactivation de RDP lorsque ce service n'est pas nécessaire.

Cette étape permet ainsi d'établir une comparaison avant/après durcissement. Une nouvelle vérification est effectuée après l'application des mesures de sécurité afin de déterminer si le risque identifié lors de l'audit initial a été réduit.

3.3.3 Mise en œuvre du durcissement

Le durcissement a été réalisé selon deux approches complémentaires : des mesures appliquées automatiquement par un script PowerShell et des mesures nécessitant une intervention manuelle.

Exécution du script de durcissement

Le script PowerShell de durcissement a été exécuté avec des privilèges administrateur sur le poste Windows 11. Il permet d'appliquer les paramètres de sécurité définis et d'indiquer l'état de chaque contrôle après son traitement. Les résultats sont présentés sous différents états, notamment `[APPLIQUÉ]` lorsque la mesure a été correctement appliquée, `[DÉJÀ OK]` lorsque le paramètre était déjà conforme et `[MANUEL]` lorsqu'une intervention supplémentaire est nécessaire (figure 3.5).

Mesures appliquées automatiquement

Le script PowerShell a permis d'appliquer plusieurs paramètres de sécurité, notamment :

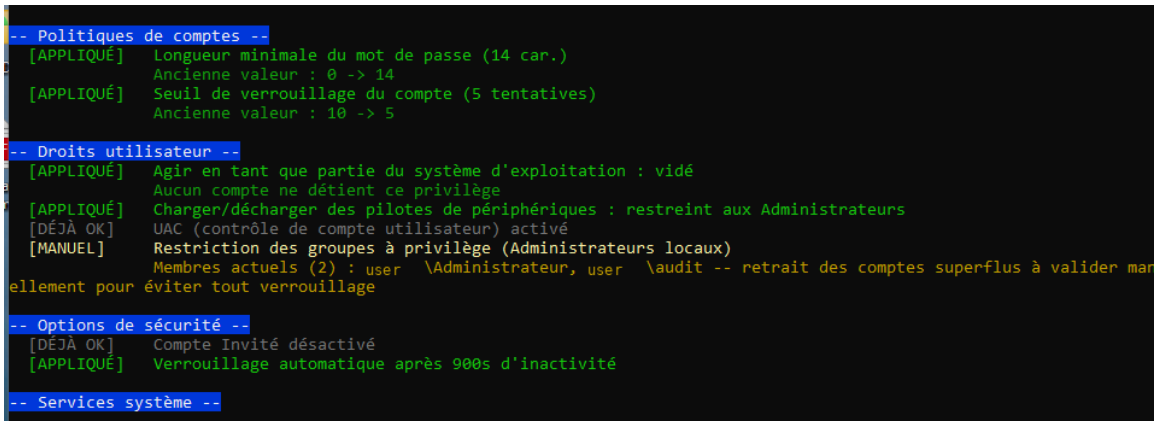


Figure 3.5 – Exécution du script de durcissement du poste Windows 11

- une longueur minimale de mot de passe de 14 caractères ;
- un seuil de verrouillage du compte après 5 tentatives échouées ;
- la suppression des privilèges système non nécessaires ;
- la restriction du chargement et du déchargement des pilotes aux administrateurs ;
- la désactivation du compte Invité ;
- le verrouillage automatique du poste après 900 secondes d'inactivité.

Mesures appliquées manuellement

Certaines recommandations ont été configurées manuellement afin de compléter le travail du script. Les principales mesures sont :

- augmentation de la taille maximale du journal de sécurité ;
- configuration d'AppLocker et de ses règles par défaut ;
- configuration du service AppIDSvc ;
- renommage du compte Administrateur local ;
- activation de l'audit des validations d'informations d'identification, pour les succès et les échecs ;
- activation de la sécurité basée sur la virtualisation (VBS) ;
- activation de HVCI à travers l'intégrité de la mémoire ;
- revue des comptes utilisateurs et de leurs privilèges.

Le contrôle relatif aux heures de connexion dépend d'un environnement Active Directory ou Entra ID. Il a donc été considéré comme non applicable dans l'environnement Windows 11 autonome utilisé pour les tests. Le tableau 3.2 synthétise les principales mesures de durcissement.

3.3.4 Résultats après durcissement

Après l'application des mesures de durcissement automatiques et manuelles, un nouvel audit de sécurité a été réalisé sur le poste Windows 11. L'objectif de cette étape est de vérifier l'évolution du niveau de conformité par rapport à l'état initial.

Le rapport généré après durcissement évalue 40 paramètres de sécurité selon les recommandations du CIS Microsoft Windows 11 Benchmark et du référentiel DNSSI. Les résultats obtenus sont les suivants :

Tableau 3.2 – Synthèse des principales mesures de durcissement

Domaine	Mesure	Application
Authentification	Mot de passe minimal de 14 caractères et verrouillage après 5 échecs	Automatique
Privilèges	Restriction des privilèges et des pilotes	Automatique
Session	Verrouillage après 900 secondes d'inactivité	Automatique
Journalisation	Augmentation de la taille du journal Security et audit des identifications	Manuel
Contrôle applicatif	Configuration d'AppLocker	Manuel
Comptes	Renommage de l'Administrateur et revue des comptes	Manuel
Protection système	Activation de VBS et HVCI	Manuel

- 26 paramètres sont conformes ;
- 4 paramètres restent non conformes ;
- 10 paramètres nécessitent une vérification manuelle ;
- le taux global de conformité atteint 85 %.



Figure 3.6 – Rapport d'état de sécurité après durcissement de Windows 11

Les résultats montrent une amélioration significative de la configuration de sécurité du poste. Plusieurs paramètres initialement non conformes ont été corrigés grâce aux mesures automatisées et aux configurations manuelles.

Détail des contrôles après durcissement

Afin de compléter la synthèse précédente, le détail des 40 contrôles évalués est présenté dans la figure 3.7. Cette vue permet d'identifier précisément les paramètres conformes, les paramètres non conformes ainsi que ceux nécessitant une vérification manuelle.

Le tableau montre notamment que plusieurs mesures relatives aux politiques de comptes, aux droits utilisateurs, aux services système, au pare-feu Windows et à la protection réseau sont désormais conformes. Les paramètres restant non conformes ou nécessitant une vérification manuelle font l'objet d'une analyse spécifique afin de distinguer les mesures pouvant encore être corrigées des limitations liées à l'environnement de laboratoire.

Analyse des paramètres restant non conformes

Malgré l'amélioration obtenue, quatre paramètres restent non conformes après l'application du durcissement. Leur analyse montre que ces écarts sont principalement liés aux contraintes de

Détail des contrôles (état après durcissement)

Catégorie	Paramètre (Réf. CIS)	Niveau	Sévérité	Valeur préconisée	Valeur constatée	Statut	Remarque
Politiques de comptes	Longueur minimale du mot de passe (1.1.4)	L1	Élevée	14 caractères ou plus	14 caractères	Conforme	-
Politiques de comptes	Seuil de verrouillage du compte (1.2.2)	L1	Élevée	5 tentatives ou moins	5 tentative(s)	Conforme	-
Droits Utilisateur	Agir en tant que partie du système d'exploitation (2.2.3)	L1	Critique	Aucun (No One)	Aucun	Conforme	-
Droits Utilisateur	Charger et décharger des pilotes de périphériques (2.2.25)	L1	Élevée	Administrateurs uniquement	*S-1-5-32-544	Conforme	-
Droits Utilisateur	Restriction des groupes à privilège (Restricted Groups / LAPS)	L1	Critique	Groupe Administrateurs local limité et inventorié	2 membre(s) : user \audit; user \LocalAdmin_EMI	Conforme	-
Droits Utilisateur	Utilisation de comptes standards pour les tâches courantes (UAC / Admin Approval Mode)	L1	Élevée	Compte standard pour l'usage quotidien, élévation via UAC	UAC activé	Conforme	-
Options de Sécurité	État du compte Invité (2.3.1.1)	L1	Élevée	Désactivé	Désactivé	Conforme	-
Options de Sécurité	Limite d'inactivité de la machine (2.3.7.3)	L1	Moyenne	900 secondes ou moins	900 secondes	Conforme	-
Services Système	Spouleur d'impression (5.17)	L2	Élevée	Désactivé	Stopped / Démarrage: Disabled	Conforme	-
Services Système	Registre distant (5.24)	L2	Élevée	Désactivé	Stopped / Démarrage: Disabled	Conforme	-
Services Système	Gestion des mises à jour (Windows Update for Business)	L1	Critique	Application automatique et priorisée des correctifs de sécurité	AUOptions = 4	Conforme	-
Services Système	Sauvegarde des configurations système (System State / GPO Backup)	L1	Moyenne	Sauvegarde automatisée après chaque changement de configuration	Non vérifiable localement	Manuel	Vérifier la procédure de sauvegarde auprès de l'équipe infrastructure
Pare-feu Windows	État du pare-feu (Profil Domaine/Privé/Public) (9.1.1)	L1	Critique	Activé	Domain: Activé | Private: Activé | Public: Activé	Conforme	-
Audit Avancé	Audit de la validation des informations d'identification (17.1.1)	L1	Moyenne	Succès et Échec	-	Non conforme	La stratégie d'audit avancée a été configurée, mais le contrôle reste non conforme car le script d'audit ne détecte pas la configuration attendue ou une stratégie locale/GPO n'a pas encore été prise en compte. Une vérification avec auditpol est nécessaire.
Audit Avancé	Synchronisation de l'horloge système (service Windows Time - w32time)	L1	Moyenne	Actif	Running / Démarrage: Automatic	Conforme	-
Audit Avancé	Taille et rétention des journaux d'événements (Event Log)	L1	Élevée	Taille maximale augmentée, rétention ≥ 6 mois ou centralisée SIEM	Journal Sécurité : 1024 Mo	Conforme	-
Modèles d'admin.	Exécution automatique (18.10.8.2)	L1	Élevée	Ne pas exécuter	NoDriveTypeAutoRun = 255	Conforme	-
Modèles d'admin.	Restriction d'installation des logiciels (AppLocker / Restrictions logicielles)	L2	Élevée	Liste blanche d'applications autorisées	10 règle(s) AppLocker active(s)	Conforme	-
Accès & Comptes	Renommer le compte administrateur (2.3.1.3)	L1	Moyenne	Nom non générique	Nom actuel : LocalAdmin_EMI	Conforme	-
Accès & Comptes	Restriction des plages horaires de connexion (Logon Hours)	L2	Moyenne	Connexions limitées aux plages horaires métier définies	Dépend de la configuration Active Directory / Entra ID	Manuel	À vérifier dans les propriétés des comptes AD
Accès & Comptes	Revue périodique des comptes et détection des doublons (audit AD / Entra ID)	L1	Moyenne	Revue au moins annuelle des comptes actifs et des identifiants redondants	Non vérifiable localement	Manuel	À vérifier auprès de l'équipe IAM
Système & VBS	Sécurité basée sur la virtualisation (18.9.5.1)	L1	Critique	Activé	Statut runtime = 1	Non conforme	La fonctionnalité dépend du support matériel (VT-x/AMD-V), de Secure Boot et de la configuration de la machine virtuelle VMware. Malgré l'activation des paramètres Windows, l'environnement virtuel ne permet pas l'activation complète de VBS.
Système & VBS	Protection de l'intégrité du code (18.9.5.3)	L1	Élevée	Activé + Verrou UEFI	HVCI inactif (constaté au runtime)	Non conforme	HVCI nécessite VBS, Secure Boot et un hyperviseur compatible. Dans l'environnement VMware utilisé pour les tests, ces prérequis ne sont pas entièrement disponibles, ce qui empêche son activation.
Chiffrement	BitLocker : Récupération (18.10.10.1.2)	L1+BL	Élevée	Activé	Protection : Off	Non conforme	BitLocker n'a pas été activé car son déploiement nécessite la gestion des clés de récupération (TPM, Active Directory ou Microsoft Entra ID) afin d'éviter la perte d'accès aux données. Cette fonctionnalité n'a pas été mise en œuvre dans l'environnement de test.
Chiffrement	BitLocker : Écriture sur supports amovibles (18.10.10.3.14)	L1+BL	Élevée	Activé	Écriture refusée si non chiffré	Conforme	-
Chiffrement	Chiffrement des connexions VPN (tunnelisation)	L1	Élevée	Protocoles VPN chiffrés (IKEv2/TLS) uniquement	Dépend de la configuration de la passerelle VPN	Manuel	À vérifier auprès de l'équipe réseau
Chiffrement	Politique de certificats (durée de validité, algorithme, longueur de clé)	L1	Élevée	Certificats ≤ 1 an, algorithme SHA-256 minimum, clé ≥ 2048 bits	Dépend de la PKI / autorité de certification	Manuel	À vérifier auprès de l'équipe PKI
Protection Réseau	SMBv1 Client & Serveur (18.4.2 / 18.4.3)	L1	Élevée	Désactivé	État : Disabled	Conforme	-
Protection Réseau	Résolution de noms Multicast - LLMNR (18.6.4.4)	L1	Élevée	Désactivé	Désactivé	Conforme	-
Protection Réseau	Sécurisation du Bureau à distance (RDP)	L1	Élevée	Authentification au niveau réseau (NLA) + chiffrement TLS	NLA activée	Conforme	-
Protection Réseau	Sécurisation du télétravail (VPN Always On + accès conditionnel)	L1	Élevée	VPN systématique avec authentification forte et vérification de conformité du poste	Dépend de la solution VPN / Intune déployée	Manuel	À vérifier auprès de l'équipe infrastructure
Protection Réseau	Contrôle des équipements autorisés sur le réseau (802.1X / NAC)	L2	Élevée	Authentification 802.1X obligatoire pour toute connexion filaire/Wi-Fi	Dépend de la configuration des commutateurs / contrôleurs Wi-Fi	Manuel	À vérifier auprès de l'équipe réseau
Défense OS	Microsoft Defender : Protection en temps réel (18.10.42.10.3)	L1	Critique	Activé (la désactivation doit être bloquée)	Protection en temps réel activée	Conforme	-
Défense OS	Microsoft Defender SmartScreen (18.10.77.2.1)	L1	Élevée	Avertir et bloquer	Activé - Niveau : Block	Conforme	-
Confidentialité	Synchronisation du presse-papiers (18.9.33.1)	L2	Moyenne	Désactivé	Désactivé	Conforme	-
Confidentialité	Publicité et identifiant publicitaire (18.9.51.1)	L2	Faible	Désactivé	Désactivé	Conforme	-
Confidentialité	Chiffrement de la messagerie et des pièces jointes sensibles	L2	Moyenne	Chiffrement S/MIME activé pour les messages sensibles	Dépend de la configuration du client de messagerie / Exchange	Manuel	À vérifier auprès de l'équipe messagerie
Confidentialité	Classification et étiquetage des données (Windows Information Protection / Microsoft Purview)	L2	Moyenne	Étiquetage automatique selon la sensibilité + protection WIP activée	Dépend de la configuration Microsoft Purview / Intune	Manuel	À vérifier auprès de l'équipe conformité
Gestion des appareils mobiles	Inscription et conformité des postes (MDM / Intune)	L1	Élevée	Postes joints à un MDM avec stratégies de conformité obligatoires	Poste inscrit à un fournisseur MDM	Conforme	-
Gestion des actifs	Inventaire automatisé des postes et logiciels (SCCM / Intune)	L1	Moyenne	Inventaire matériel/logiciel centralisé et mis à jour automatiquement	Non vérifiable localement	Manuel	À vérifier auprès de l'équipe gestion des actifs

Figure 3.7 – Détail des contrôles de sécurité après durcissement

l'environnement de laboratoire virtualisé.

Les contrôles relatifs à la sécurité basée sur la virtualisation (VBS) et à l'intégrité du code protégée par hyperviseur (HVCI) dépendent notamment des fonctionnalités de virtualisation matérielle, du démarrage sécurisé et de la configuration de l'hyperviseur utilisé pour la machine virtuelle Windows 11. De même, certains contrôles relatifs à BitLocker peuvent dépendre de la présence et de la configuration d'un TPM virtuel ainsi que de la configuration du stockage de la machine virtuelle.

Ces limitations sont donc à interpréter dans le contexte de l'environnement de test utilisé. Elles ne remettent pas en cause les mesures de durcissement qui ont pu être appliquées et vérifiées sur le poste (tableau 3.3).

Tableau 3.3 – Analyse des principales non-conformités restantes

Paramètre	Justification
VBS	Dépend de la configuration de la virtualisation matérielle, du démarrage sécurisé et de l'hyperviseur utilisé.
HVCI	Dépend notamment de VBS, de la compatibilité des pilotes et des mécanismes de sécurité disponibles dans l'environnement virtualisé.
BitLocker – récupération	La validation complète dépend de la disponibilité et de la configuration du TPM dans l'environnement de test.
BitLocker – protection	La mise en œuvre complète du chiffrement dépend de la configuration matérielle et du mécanisme TPM disponible.

Ainsi, les quatre non-conformités restantes sont principalement liées aux contraintes techniques de l'environnement de laboratoire et non à l'absence de mise en œuvre des mesures de sécurité applicables.

3.3.5 Nouvelle simulation d'attaque après durcissement

Afin de valider expérimentalement l'efficacité des mesures de durcissement, une seconde simulation d'attaque par force brute a été réalisée depuis la machine Kali Linux. Le même scénario que celui utilisé avant durcissement a été conservé afin de permettre une comparaison objective des résultats : le compte de test `audit` et la même liste de mots de passe ont été utilisés contre le service RDP du poste Windows 11. La commande exécutée depuis Kali Linux est la suivante :

```
hydra -l audit -P passwords.txt -V rdp://192.168.100.136
```

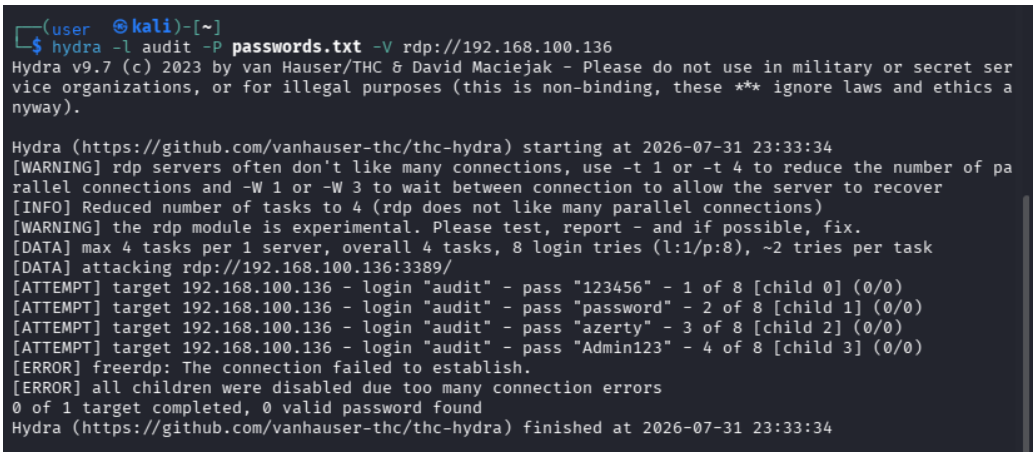


Figure 3.8 – Simulation de force brute RDP après durcissement

Contrairement à la simulation réalisée avant durcissement, aucune combinaison valide n'a été identifiée au cours de cette seconde tentative. Hydra indique :

```
0 of 1 target completed, 0 valid password found
```

Le résultat indique donc qu'aucun des mots de passe présents dans la liste de test n'a permis d'obtenir une authentification valide sur le service RDP.

La sortie de l'outil indique également plusieurs erreurs de connexion *freerdp*, suivies de l'arrêt des tentatives parallèles après plusieurs erreurs. Ce comportement est cohérent avec les mécanismes de protection et de limitation des tentatives d'authentification mis en place lors du durcissement.

Il convient néanmoins de distinguer l'absence de mot de passe valide dans cette simulation d'une impossibilité absolue de compromettre le service. Le test permet de confirmer que le scénario de force brute utilisé dans le laboratoire n'a pas permis d'obtenir une authentification valide après durcissement.

3.3.6 Comparaison avant et après durcissement

Afin de mesurer l'efficacité des actions réalisées, les résultats de l'audit initial ont été comparés à ceux obtenus après durcissement (tableau 3.4).

Tableau 3.4 – Évolution du niveau de conformité de Windows 11 après durcissement

Indicateur	Avant durcissement	Après durcissement
Paramètres conformes	10	26
Paramètres non conformes	20	4
Paramètres à vérifier manuellement	10	10
Taux de conformité	25 %	85 %

Le nombre de paramètres conformes est ainsi passé de 10 à 26, tandis que le nombre de paramètres non conformes a diminué de 20 à 4. Le taux global de conformité est passé de 25 % à 85 %. Cette évolution confirme l'efficacité globale des mesures de durcissement appliquées au

poste Windows 11.

3.4 Durcissement du pare-feu FortiGate

Après l'étude et le durcissement du poste Windows 11, une démarche similaire a été appliquée au pare-feu FortiGate utilisé dans l'environnement de laboratoire. L'objectif est d'évaluer la configuration initiale du pare-feu, d'identifier les écarts de sécurité et de mettre en évidence les paramètres nécessitant une action corrective.

3.4.1 Environnement du FortiGate

Le pare-feu utilisé dans le cadre de cette étude est une machine virtuelle *FortiGate-VM64*. La configuration analysée correspond à la version FortiOS v7.2.0, build 1157. L'adresse IP utilisée pour l'administration du pare-feu dans l'environnement de laboratoire est 192.168.1.2. L'audit a été réalisé à distance depuis l'environnement de test et porte sur les différents paramètres de configuration et de sécurité du FortiGate.

3.4.2 Audit initial

Un audit initial de la configuration du FortiGate a été réalisé avant l'application des mesures de durcissement. La grille d'évaluation utilisée comporte 56 contrôles de sécurité issus du référentiel retenu pour l'étude. Les résultats de l'audit initial sont les suivants :

- 5 contrôles conformes ;
- 10 contrôles non conformes ;
- 40 contrôles partiellement conformes ;
- 1 contrôle nécessitant une vérification ;
- un taux de conformité global de 8,9 %.

Ces résultats montrent que la configuration initiale présente un niveau de conformité faible et plusieurs écarts nécessitant des mesures correctives. La figure 3.9 présente la synthèse du rapport généré avant l'application des mesures de durcissement.



Figure 3.9 – Rapport d'audit initial du FortiGate

Analyse des écarts identifiés

L'analyse des résultats de l'audit initial permet d'identifier plusieurs domaines présentant des

écarts de sécurité. Les principales catégories concernées sont notamment :

- la gestion des comptes administrateurs ;
- la politique de mots de passe ;
- le contrôle des accès d'administration ;
- les services d'administration exposés ;
- la journalisation des événements ;
- la configuration des mécanismes de protection réseau ;
- les paramètres de sécurité des interfaces ;
- les mécanismes de filtrage et de contrôle du trafic.

Certains contrôles sont classés comme **non conformes**, tandis que d'autres sont considérés comme **partiellement conformes**. Cette distinction permet de prioriser les actions de durcissement (tableau 3.5).

Tableau 3.5 – Synthèse de l'audit initial du FortiGate

État du contrôle	Nombre
Conforme	5
Non conforme	10
Partiellement conforme	40
À vérifier	1
Total	**56**

Ainsi, l'audit initial constitue l'état de référence permettant de mesurer l'efficacité des mesures de durcissement appliquées dans la suite de l'étude.

3.4.3 Analyse de l'exposition réseau avant durcissement

En complément de l'audit de configuration, une reconnaissance réseau du FortiGate a été réalisée depuis la machine Kali Linux. Cette étape permet d'identifier les services accessibles depuis le réseau de test avant l'application des mesures de durcissement.

Dans un premier temps, un contrôle du certificat TLS du service HTTPS a été effectué à l'aide du script NSE `ssl-cert` de Nmap :

```
nmap --script ssl-cert -p 443 192.168.1.2
```

Le résultat confirme que l'hôte 192.168.1.2 est accessible et que le port TCP 443, correspondant au service HTTPS d'administration, est ouvert (figure 3.10).

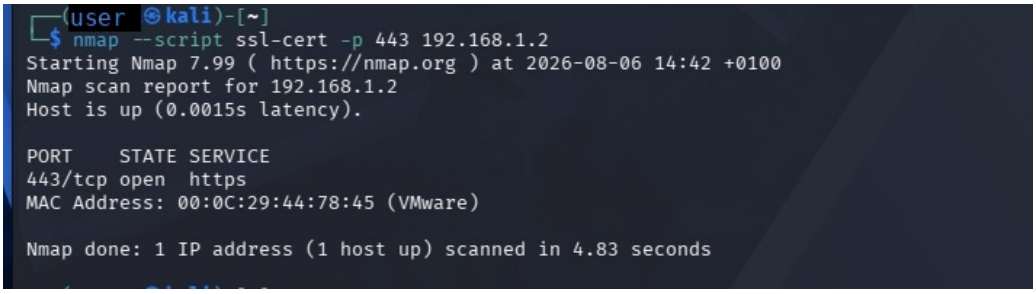


Figure 3.10 – Identification du service HTTPS du FortiGate avant durcissement

Une seconde reconnaissance plus complète a ensuite été réalisée avec Nmap à l'aide des options de détection de services et du système d'exploitation :

```
sudo nmap -A 192.168.1.2
```

Cette analyse a permis d'identifier notamment les éléments suivants (figure 3.11) :

- **80/tcp** : service HTTP, identifié comme `tcpwrapped` ;
- **443/tcp** : service HTTPS, également identifié comme `tcpwrapped` ;
- le système cible est identifié comme un équipement Fortinet ;
- Nmap estime la version du système comme appartenant à la famille FortiOS 6.2–7.2.

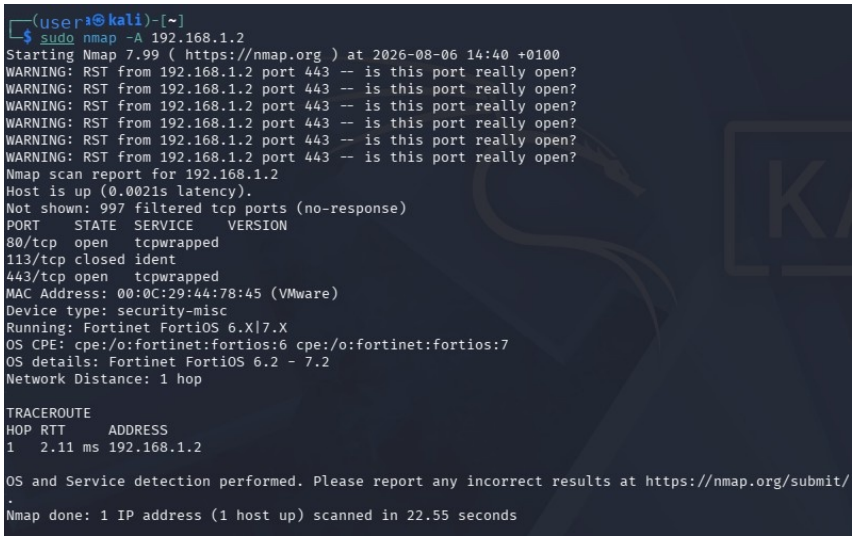


Figure 3.11 – Reconnaissance des services du FortiGate avant durcissement

Ces résultats permettent d'établir une première photographie de la surface réseau exposée du pare-feu avant durcissement. Ils servent de référence pour la comparaison avec les résultats obtenus après application des mesures de sécurité. Il convient toutefois de préciser que la détection d'un port ouvert par Nmap ne constitue pas à elle seule la preuve d'une vulnérabilité : elle permet principalement d'identifier les services accessibles et d'orienter les contrôles de sécurité et les actions de durcissement.

3.4.4 Mise en œuvre du durcissement du FortiGate

À la suite de l'audit initial du pare-feu FortiGate, une phase de durcissement a été mise en œuvre afin de corriger les écarts identifiés et de renforcer la sécurité de la configuration. La démarche adoptée combine des mesures automatisées à l'aide d'un script de durcissement et des mesures configurées ou vérifiées manuellement. Cette approche permet d'une part d'automatiser les paramètres pouvant être appliqués de manière reproductible et, d'autre part, de traiter manuellement les paramètres dépendant de l'architecture du laboratoire et des besoins d'administration.

Mesures automatisées

Une partie des mesures de sécurité a été appliquée à l'aide d'un script de durcissement exécuté sur le FortiGate. Le script permet également de contrôler l'état des différents paramètres

et d'indiquer leur niveau de conformité. Les principales mesures automatisées concernent la configuration globale du pare-feu et la sécurisation des accès d'administration :

- **personnalisation du nom d'hôte** : un nom d'hôte explicite a été défini afin de faciliter l'identification du pare-feu dans l'environnement de test ;
- **renforcement de la politique de mots de passe** : une longueur minimale du mot de passe ainsi qu'une politique de renouvellement ont été configurées ;
- **verrouillage du compte administrateur** : un mécanisme de verrouillage est configuré après plusieurs tentatives d'authentification échouées afin de limiter les attaques par force brute ;
- **expiration des sessions d'administration** : une durée maximale d'inactivité est définie afin d'éviter qu'une session d'administration laissée ouverte reste accessible indéfiniment ;
- **activation du chiffrement fort** : les mécanismes cryptographiques renforcés sont activés afin d'améliorer la sécurité des communications d'administration ;
- **restriction des versions TLS** : l'interface d'administration Web est configurée afin d'utiliser des versions récentes de TLS ;
- **activation des bannières de connexion** : des messages d'information et d'avertissement sont affichés lors de l'accès à l'interface d'administration ;
- **personnalisation des paramètres d'administration** : les paramètres relatifs aux ports et aux services d'administration sont adaptés à l'environnement de test.

Un extrait représentatif du script utilisé est présenté ci-dessous. Il illustre notamment le renforcement de la politique d'authentification, le verrouillage des comptes, la limitation de la durée des sessions ainsi que le renforcement des communications d'administration.

```
config system global
    set hostname "FW-LAB-01"
    set timezone 40
    set admin-password-expire 90
    set admin-password-min-length 12
    set admin-password-change enable
    set admin-lockout-threshold 5
    set admin-lockout-duration 900
    set admin-session-timeout 600
    set strong-crypto enable
    set admin-https-ssl-versions tlsv1-2 tlsv1-3
    set admin-https-pki-required enable
    set pre-login-banner enable
    set post-login-banner enable
    set admin-port 8443
    set admin-https-port 8443
    set admin-ssh-port 22
end
```

Mesures configurées manuellement

Certains paramètres nécessitant une adaptation à l'environnement du laboratoire ont été configurés ou vérifiés manuellement. Ces interventions complètent les mesures appliquées automatiquement par le script. Les principales mesures manuelles réalisées sont les suivantes :

- **modification du mot de passe administrateur** : le mot de passe du compte administrateur

a été modifié afin de remplacer le mot de passe initial par un mot de passe plus robuste ;
- **restriction des hôtes de confiance** : les adresses IP autorisées à administrer le FortiGate ont été restreintes afin de limiter l'accès aux fonctions d'administration aux sources autorisées ;
- **restriction de l'accès SSH** : l'accès d'administration à distance via SSH a été limité afin de réduire la surface d'exposition du service d'administration ;
- **sécurisation de l'accès HTTPS** : l'accès à l'interface graphique d'administration a été configuré via HTTPS afin de protéger les échanges d'administration ;
- **configuration de la journalisation** : les paramètres de journalisation ont été vérifiés et configurés afin d'assurer la traçabilité des événements et des tentatives d'accès ;
- **synchronisation temporelle** : la configuration du service NTP a été vérifiée afin de garantir une référence temporelle cohérente pour les journaux et les événements de sécurité ;
- **vérification des services d'administration** : les services accessibles sur les interfaces du FortiGate ont été vérifiés afin de limiter l'exposition aux services nécessaires.

Ces mesures manuelles ont été réalisées en tenant compte de l'architecture réseau virtuelle utilisée pour le laboratoire. Leur configuration permet de conserver les accès nécessaires aux opérations d'administration tout en réduisant les possibilités d'accès non autorisés.

3.4.5 Audit après durcissement du FortiGate

À l'issue de la phase de durcissement, une seconde évaluation de la configuration du FortiGate a été réalisée à l'aide de la même checklist de conformité composée de 56 contrôles. L'utilisation de la même grille permet de comparer de manière homogène l'état initial et l'état final du pare-feu.

L'audit de vérification réalisé après l'application des mesures de sécurité montre une amélioration significative du niveau de conformité. Le FortiGate atteint un taux de conformité global de **80,4 %**, avec **45 contrôles conformes sur 56**. Les résultats obtenus sont répartis comme suit :

- **45 contrôles conformes**, soit 80,4 % des contrôles évalués ;
- **2 contrôles non conformes**, nécessitant encore une action corrective ;
- **7 contrôles partiellement conformes**, pour lesquels certains éléments de la recommandation sont appliqués mais nécessitent encore une amélioration ;
- **2 contrôles non applicables** dans le contexte de l'environnement de laboratoire ;
- **0 contrôle à vérifier**, indiquant que l'ensemble des contrôles évalués a pu être traité lors de cette phase.

La figure 3.12 présente le rapport généré après l'application des mesures de durcissement. Elle met en évidence l'évolution du niveau de conformité du pare-feu et permet d'identifier les contrôles nécessitant encore des améliorations.

3.4.6 Justification des contrôles non conformes

Après le durcissement, deux contrôles restent non conformes (tableau 3.6). Ces écarts sont principalement liés aux contraintes de l'environnement de laboratoire.

Ces deux écarts sont donc liés aux contraintes spécifiques de l'environnement expérimental. Le premier résulte de l'utilisation d'une seule appliance, tandis que le second est lié à la gestion

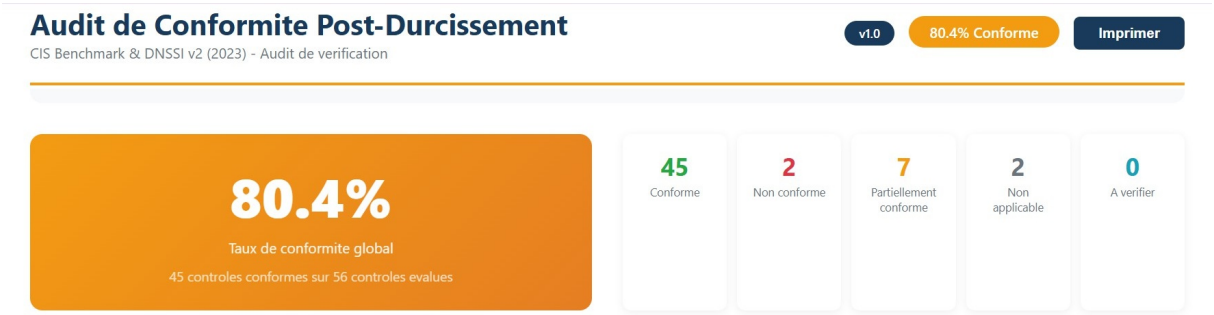


Figure 3.12 – Rapport d'audit de conformité du FortiGate après durcissement

Tableau 3.6 – Justification des contrôles non conformes

Contrôle	État	Justification
Configuration HA activée	Non conforme	Le contrôle n'est pas applicable dans le laboratoire, car l'environnement utilise une seule appliance FortiGate. La haute disponibilité nécessite plusieurs équipements pour assurer la redondance.
Dernier firmware installé	Non conforme	La mise à jour du firmware n'a pas été réalisée dans l'environnement de test, car une modification de version peut présenter un risque pour la stabilité et le fonctionnement de la plateforme de laboratoire.

du firmware dans une plateforme de test. Les autres mesures de durcissement ont pu être appliquées et vérifiées dans l'environnement mis en place.

3.4.7 Comparaison avant et après durcissement

Afin de mesurer l'efficacité des mesures de durcissement appliquées au FortiGate, les résultats de l'audit initial ont été comparés à ceux obtenus après leur mise en œuvre (tableau 3.7).

Tableau 3.7 – Évolution du niveau de conformité du FortiGate avant et après durcissement

Indicateur	Avant durcissement	Après durcissement
Contrôles conformes	5	45
Contrôles non conformes	10	2
Contrôles partiellement conformes	40	7
Contrôles à vérifier	1	0
Contrôles non applicables	0	2
Taux de conformité	8,9 %	80,4 %

Le nombre de contrôles conformes est passé de **5 à 45**, tandis que les contrôles non conformes ont diminué de **10 à 2**. Les contrôles partiellement conformes sont également passés de **40 à 7**. Le taux global de conformité est ainsi passé de **8,9 % à 80,4 %**, soit une amélioration de **71,5**

points de pourcentage. Cette évolution met en évidence l'efficacité globale des mesures de durcissement appliquées au FortiGate et l'amélioration significative de son niveau de sécurité.

3.5 Conclusion

Ce chapitre a présenté les mesures de durcissement et leur validation sur Windows 11 et FortiGate. Les résultats montrent une amélioration significative du niveau de conformité, passant de 25 % à 85 % pour Windows 11 et de 8,9 % à 80,4 % pour FortiGate. Les audits et simulations réalisés avant et après durcissement ont permis de vérifier l'efficacité des mesures appliquées et d'identifier les écarts résiduels liés principalement aux contraintes du laboratoire.

Conclusion générale

Dans le cadre de ce projet, une démarche d'audit de sécurité et de durcissement a été menée sur deux actifs du système d'information : un poste de travail Windows 11 et un pare-feu FortiGate. L'objectif était d'évaluer leur niveau de conformité à partir des référentiels de sécurité retenus, d'identifier les écarts et de mettre en œuvre des mesures correctives adaptées.

Les audits initiaux ont permis d'identifier plusieurs paramètres nécessitant des améliorations. Une phase de durcissement a ensuite été réalisée en combinant des mesures automatisées à l'aide de scripts et des configurations effectuées manuellement. Des simulations de sécurité ont également été réalisées avant et après durcissement afin de vérifier l'efficacité des mesures appliquées.

Les résultats obtenus montrent une amélioration significative du niveau de conformité. Pour Windows 11, le taux de conformité est passé de **25 % à 85 %**, tandis que celui du FortiGate est passé de **8,9 % à 80,4 %**. Ces résultats montrent l'intérêt d'une approche structurée combinant audit, remédiation et validation.

Perspectives

La principale perspective de ce travail consiste à appliquer la démarche proposée dans un **environnement réel de production**. Une telle mise en œuvre nécessiterait d'adapter les mesures de durcissement à l'architecture existante, aux contraintes opérationnelles et aux politiques de sécurité de l'organisation.

À terme, cette démarche pourrait être étendue à un plus grand nombre d'actifs du système d'information et intégrée dans un processus régulier d'audit et de contrôle de conformité. La centralisation des journaux, l'automatisation des contrôles, la surveillance continue ainsi que la réalisation périodique de tests de sécurité constitueraient également des axes d'amélioration.

Ainsi, ce projet constitue une base pour une démarche de **sécurisation continue des actifs du système d'information**, depuis l'identification des écarts jusqu'à leur correction et leur validation.

Bibliographie

[1] Center for Internet Security (CIS), *CIS Benchmark for Microsoft Windows 11*. Disponible sur : https://downloads.cisecurity.org/

[2] Center for Internet Security (CIS), *CIS Benchmark for FortiGate/FortiOS*. Disponible sur : https://downloads.cisecurity.org/

[3] Direction Générale de la Sécurité des Systèmes d'Information (DGSSI), *Directive Nationale de Sécurité des Systèmes d'Information (DNSSI)*. Disponible sur : https://www.dgssi.gov.ma/

[4] Royaume du Maroc, *Loi n°05-20 relative à la cybersécurité*. Disponible sur : https://www.dgssi.gov.ma/fr/

[5] Fortinet, *Documentation FortiOS*. Disponible sur : https://docs.fortinet.com/

[6] Microsoft, *Documentation de sécurité Windows*. Disponible sur : https://www.microsoft.com/fr-fr/software-download/windows11

[7] TechTarget, *What is a Security Audit ? – Definition, Types and Best Practices*. Disponible sur : https://www.techtarget.com/searchcio/definition/security-audit